DOCUMENTO TÉCNICO OFICIAL

Sistema de Gestión de Contenido DIF San Mateo Atenco

Documentación técnica completa del sistema CMS institucional □ PHP 8 / MySQL 8 / Bootstrap 5

Versión: 1.0.0 **Base de datos:** difsanma_dif_cms **Entorno:** PHP 8.x / MySQL 8.0.45 / Apache **Clasificación:** Uso Interno □ Confidencial

Institución: DIF San Mateo Atenco, Estado de México

Sección 01

Información General del Proyecto

1.1 Identificación del Sistema

Atributo	Valor
Nombre del sistema	DIF San Mateo Atenco □ Sistema de Gestión de Contenido (CMS)
Nombre técnico	`dif-cms`
Versión actual	1.0.0
Tipo de sistema	Aplicación web institucional □ CMS a medida
Institución cliente	Sistema para el Desarrollo Integral de la Familia □ Municipio de San Mateo Atenco, Estado de México
Base de datos	`difsanma_dif_cms`
Lenguaje principal	PHP 8.x (backend) / JavaScript ES6+ (frontend)
Motor de base de datos	MySQL 8.0.45 □ charset `utf8mb4_unicode_ci`
Servidor web	Apache 2.4 (XAMPP local / cPanel hosting compartido)
Clasificación	Uso interno □ Confidencial

1.2 Descripción General

El Sistema de Gestión de Contenido (CMS) del DIF San Mateo Atenco es una aplicación web institucional desarrollada a medida en PHP 8 con base de datos MySQL 8. Su propósito es permitir que el personal administrativo de la institución gestione de forma autónoma, segura y eficiente todos los contenidos del sitio web público del DIF, sin necesidad de conocimientos técnicos de programación.

El sistema provee un panel de administración protegido por autenticación de sesiones PHP, con protección CSRF, control de intentos de inicio de sesión y un sistema de permisos granular por sección. El sitio público consume los datos almacenados en MySQL y los presenta mediante plantillas PHP con Bootstrap 5, animaciones CSS y componentes JavaScript modernos.

La arquitectura sigue un patrón de diseño similar a MVC (Modelo-Vista-Controlador) implementado de forma procedimental en PHP, donde cada módulo del panel de administración actúa como controlador, las consultas PDO representan el modelo y las plantillas HTML/PHP constituyen la vista.

1.3 Objetivos del Sistema

- **Gestión autónoma de contenidos:** Permitir al personal del DIF actualizar noticias, programas, trámites, galería fotográfica, sliders y documentos de transparencia sin intervención técnica externa.
- **Transparencia gubernamental:** Publicar y mantener actualizados los documentos de transparencia exigidos por la normativa: SEAC, Cuenta Pública, Presupuesto Anual, PAE, Matrices de Indicadores, CONAC e información financiera.
- **Seguridad institucional:** Garantizar que solo personal autorizado acceda al panel de administración, con registro de auditoría completo de todas las acciones realizadas.
- **Accesibilidad ciudadana:** Ofrecer al ciudadano información actualizada sobre servicios, trámites, programas sociales, voluntariado y comunicación social del DIF.
- **Escalabilidad modular:** Permitir la incorporación de nuevas secciones de transparencia mediante el módulo de secciones dinámicas sin modificar el código fuente.
- **Compatibilidad con hosting compartido:** Funcionar correctamente en entornos de hosting cPanel con PHP 8.x y MySQL 8, sin dependencias de servidor adicionales.

1.4 Alcance Funcional

El sistema cubre los siguientes dominios funcionales:

- Gestión de contenido del sitio público (sliders, programas, trámites, noticias, galería, voluntariado)
- Administración de información institucional (presidencia, direcciones, organigrama)
- Módulos de transparencia gubernamental (SEAC, Cuenta Pública, Presupuesto Anual, PAE, Matrices, CONAC, Financiero)
- Gestión de avisos de privacidad
- Configuración del footer y contacto del sitio
- Administración de usuarios y permisos del panel
- Registro de auditoría y reportes de actividad
- Subida y gestión de imágenes y documentos PDF

Sección 02

Arquitectura del Sistema

2.1 Visión General de la Arquitectura

El sistema implementa una arquitectura de tres capas (presentación, lógica de negocio y datos) sobre un stack LAMP (Linux/Apache/MySQL/PHP) en producción y WAMP/XAMPP en desarrollo local. La comunicación entre capas es síncrona mediante peticiones HTTP estándar y asíncrona mediante llamadas AJAX para operaciones de actualización parcial de la interfaz.

El patrón arquitectónico adoptado es un **MVC procedimental simplificado**: cada archivo PHP del directorio `admin/` actúa simultáneamente como controlador (procesa el POST, ejecuta la lógica de negocio) y como vista (renderiza el HTML de respuesta). Las consultas a base de datos se encapsulan mediante PDO con sentencias preparadas, actuando como capa de modelo.

2.2 Capa de Presentación (Frontend)

La capa de presentación está compuesta por plantillas PHP que generan HTML5 dinámico. El sitio público utiliza Bootstrap 5 como framework CSS base, complementado con hojas de estilo personalizadas ubicadas en `css/`. La tipografía principal es **Montserrat** (Google Fonts), con fuentes de respaldo del sistema.

Los componentes interactivos del frontend incluyen:

- **Swiper.js:** Carrusel principal de la página de inicio con transiciones suaves y autoplay configurable.
- **OwlCarousel2:** Carrusel secundario para la sección "DIF Comunica" con soporte responsive.
- **Lightbox2:** Visualizador de imágenes en modal para la galería fotográfica.
- **WOW.js + Animate.css:** Animaciones de entrada al hacer scroll en elementos de la página.
- **PDF.js:** Visualizador de documentos PDF embebido en el panel de administración.
- **jQuery:** Utilizado para manipulación DOM, AJAX y compatibilidad con plugins. Se carga desde CDN con fallback local en `lib/jquery/jquery.min.js`.

2.3 Capa de Lógica de Negocio (Backend PHP)

La lógica de negocio reside en los archivos PHP del directorio `admin/`. Cada módulo sigue el siguiente flujo de procesamiento:

1. Inclusión de `auth_guard.php` para verificar autenticación y permisos.
2. Inclusión de `csrf.php` para generación y validación de tokens CSRF.
3. Inclusión de `includes/db.php` para obtener la conexión PDO singleton.
4. Procesamiento del método POST: validación de entradas, sanitización y ejecución de la acción solicitada.
5. Registro automático de la acción en el historial de auditoría (`admin_historial`).
6. Renderizado de la vista HTML con los datos actualizados desde la base de datos.

2.4 Capa de Datos (MySQL / PDO)

La capa de datos utiliza MySQL 8.0.45 con el charset `utf8mb4_unicode_ci` para soporte completo de Unicode, incluyendo emojis y caracteres especiales del español. El acceso a la base de datos se realiza exclusivamente mediante PDO (PHP Data Objects) con las siguientes configuraciones de seguridad:

```
PDO::ATTR_ERRMODE            => PDO::ERRMODE_EXCEPTION
PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC
PDO::ATTR_EMULATE_PREPARES   => false  // Sentencias preparadas nativas
```

La función `get_db()` en `includes/db.php` implementa el patrón Singleton para reutilizar la conexión PDO durante toda la ejecución del script, evitando múltiples conexiones innecesarias a la base de datos.

2.5 Patrón de Diseño

Patrón	Implementación	Ubicación
Singleton	Conexión PDO única por request	`includes/db.php ▯ get_db()`
Guard / Middleware	Verificación de autenticación y permisos antes de cada página admin	`admin/auth_guard.php`
Token CSRF	Generación y validación de tokens criptográficos por formulario	`admin/csrf.php`
Repository (informal)	Consultas PDO encapsuladas en cada módulo	`admin/*.php`
Observer (informal)	Registro automático de acciones POST en historial	`admin/auth_guard.php`
Strategy	Plantillas de transparencia reutilizables (seac, cuenta_publica, etc.)	`trans_secciones.plantilla`

Sección 03

Tecnologías y Dependencias

3.1 Stack Tecnológico Backend

Tecnología	Versión	Rol	Notas
PHP	8.x	Lenguaje de servidor principal	Requiere extensiones: PDO, PDO_MySQL, GD, fileinfo, mbstring, session
MySQL	8.0.45	Motor de base de datos relacional	Charset: utf8mb4_unicode_ci. InnoDB como motor de tablas.
PDO	Nativo PHP 8	Abstracción de acceso a datos	Sentencias preparadas nativas (`EMULATE_PREPARES=false`)
Apache	2.4	Servidor web HTTP	mod_rewrite habilitado. Configuración via `.htaccess`
Composer	2.x	Gestor de dependencias PHP	Archivo `composer.json` presente. Dependencias mínimas.

3.2 Stack Tecnológico Frontend

Librería / Framework	Versión	Distribución	Propósito
Bootstrap	5.3.0	Local (`css/bootstrap.min.css`) + CDN JS	Framework CSS responsive, componentes UI, grid system
Bootstrap Icons	1.11.3	CDN	Iconografía vectorial SVG para el panel de administración
Font Awesome	5.x	CDN	Iconografía adicional para el sitio público
Montserrat	□	Google Fonts CDN	Tipografía principal del sitio público
jQuery	3.x	Local (`lib/jquery/jquery.min.js`) + CDN fallback	Manipulación DOM, AJAX, compatibilidad con plugins
TinyMCE	6.x	CDN (cloud.tinymce.com)	Editor de texto enriquecido (WYSIWYG) para contenido HTML
SortableJS	1.x	CDN	Reordenamiento drag & drop de elementos en el panel admin
Swiper.js	□	Local (`css/swiper-bundle.min.css` + CDN JS)	Carrusel principal de la página de inicio
OwlCarousel2	2.x	Local (`lib/owlcarousel/`)	Carrusel "DIF Comunica" con soporte responsive
Lightbox2	2.x	Local (`lib/lightbox/`)	Visualizador de imágenes en modal para galería
WOW.js	□	Local (`lib/wow/`)	Activación de animaciones CSS al hacer scroll
Animate.css	□	Local (`lib/animate/`)	Biblioteca de animaciones CSS para WOW.js

PDF.js	□	CDN (mozilla.github.io)	Visualizador de PDFs embebido en el panel admin
Easing.js	□	Local (`lib/easing/`)	Funciones de easing para animaciones jQuery

3.3 Entornos de Ejecución

Entorno	Stack	Características
Desarrollo local	XAMPP (Windows)	Apache 2.4, PHP 8.x, MySQL 8.0.45, phpMyAdmin. `APP_DEBUG=true`
Producción	Hosting compartido cPanel	Apache, PHP 8.x, MySQL 8.x. Credenciales via variables de entorno. `APP_DEBUG=false`

3.4 Extensiones PHP Requeridas

- `pdo` □ Abstracción de base de datos
- `pdo_mysql` □ Driver MySQL para PDO
- `gd` □ Procesamiento y compresión de imágenes (GD Library)
- `fileinfo` □ Detección de tipo MIME real de archivos subidos
- `mbstring` □ Manejo de cadenas multibyte (UTF-8)
- `session` □ Gestión de sesiones PHP
- `json` □ Codificación/decodificación JSON para respuestas AJAX
- `openssl` □ Generación de bytes aleatorios criptográficamente seguros (`random_bytes()`)

> **Nota de compatibilidad**
> El sistema fue desarrollado y probado con PHP 8.0+ y MySQL 8.0.45. No es compatible con PHP 7.x debido al uso de tipos de retorno, `match` expressions y otras características de PHP 8. Se recomienda PHP 8.1 o superior en producción.

Sección 04

Estructura de Archivos y Directorios

4.1 Árbol de Directorios Principal

```
/dif-cms/ # Raíz del proyecto (webroot) +-- acerca-del-dif/ # Páginas públicas: presidencia, direcciones, organigrama +-- admin/
# Panel de administración (protegido) ¦ +-- .htaccess # Protección adicional del directorio admin ¦ +-- auth_guard.php # Guard de
autenticación y permisos ¦ +-- csrf.php # Generación y validación de tokens CSRF ¦ +-- login.php # Formulario de inicio de sesión
¦ +-- logout.php # Cierre de sesión ¦ +-- dashboard.php # Panel principal con tarjetas de módulos ¦ +-- upload_handler.php #
Manejador centralizado de subida de archivos ¦ +-- historial_helper.php # Helper para registro de auditoría ¦ +--
sidebar_sections.php # Definición centralizada del sidebar ¦ +-- usuarios.php # Gestión de usuarios del panel ¦ +--
slider_principal.php # Módulo: slider principal ¦ +-- slider_comunica.php # Módulo: slider DIF Comunica ¦ +-- programas.php #
Módulo: programas sociales ¦ +-- programa_editar.php # Editor de secciones de programa ¦ +-- tramites.php # Módulo: trámites y
servicios ¦ +-- noticias.php # Módulo: noticias ¦ +-- galeria.php # Módulo: galería fotográfica ¦ +-- presidencia.php # Módulo:
presidencia del DIF ¦ +-- direcciones.php # Módulo: directores y áreas ¦ +-- organigrama.php # Módulo: organigrama institucional
¦ +-- voluntariado.php # Módulo: voluntariado ¦ +-- autismo.php # Módulo: unidad de autismo ¦ +-- footer.php # Módulo:
configuración del footer ¦ +-- institucion.php # Módulo: banner institucional ¦ +-- transparencia.php # Módulo: índice de
transparencia ¦ +-- seac.php # Módulo: SEAC (transparencia) ¦ +-- cuenta_publica.php # Módulo: cuenta pública ¦ +--
presupuesto_anual.php # Módulo: presupuesto anual ¦ +-- pae.php # Módulo: PAE ¦ +-- matrices_indicadores.php # Módulo: matrices
de indicadores ¦ +-- conac.php # Módulo: CONAC ¦ +-- financiero.php # Módulo: información financiera ¦ +-- avisos_privacidad.php
# Módulo: avisos de privacidad ¦ +-- transparencia_dinamica.php # Módulo: secciones dinámicas ¦ +-- transparencia_seccion.php #
Editor de sección dinámica ¦ +-- historial.php # Visualizador de historial de actividad ¦ +-- reportes_historial.php # Reportes y
estadísticas de actividad +-- autismo.php # Página pública: unidad de autismo +-- comunicacion-social/ # Páginas públicas:
noticias, galería +-- css/ # Hojas de estilo del proyecto ¦ +-- bootstrap.min.css # Bootstrap 5 (local) ¦ +-- style.css # Estilos
principales del sitio público ¦ +-- admin.css # Estilos del panel de administración ¦ +-- swiper-bundle.min.css # Swiper.js CSS ¦
+-- ... # Otros CSS modulares +-- database/ # Scripts SQL de creación de tablas y migraciones +-- docs/ # Documentación del
proyecto +-- img/ # Imágenes estáticas del sistema +-- includes/ # Componentes PHP reutilizables del sitio público ¦ +-- db.php #
Conexión PDO singleton ¦ +-- header.php # Cabecera HTML del sitio público ¦ +-- navbar.php # Barra de navegación ¦ +-- footer.php
# Pie de página del sitio público +-- js/ # Scripts JavaScript del proyecto ¦ +-- main.js # Script principal del sitio público ¦
+-- admin-tooltips.js # Tooltips del panel admin ¦ +-- upload-progress.js # Indicador de progreso de subida +-- lib/ # Librerías
JavaScript de terceros (local) ¦ +-- animate/ # Animate.css ¦ +-- easing/ # jQuery Easing ¦ +-- jquery/ # jQuery (fallback local)
¦ +-- lightbox/ # Lightbox2 ¦ +-- owlcarousel/ # OwlCarousel2 ¦ +-- wow/ # WOW.js +-- logs/ # Logs del sistema
(upload_errors.log, login_attempts.log) +-- uploads/ # Archivos subidos por los administradores ¦ +-- images/ # Imágenes subidas
(JPG, PNG, WEBP) ¦ +-- pdfs/ # Documentos PDF subidos +-- config.php # Configuración global (DB, rutas, límites) +-- index.php #
Página de inicio del sitio público +-- .htaccess # Configuración Apache (rewrite, seguridad) +-- composer.json # Dependencias PHP
(Composer)
```

4.2 Archivos de Configuración Críticos

Archivo	Propósito	Sensibilidad

`config.php`	Constantes globales: credenciales DB, rutas, límites de subida, modo debug	CRÍTICO
`includes/db.php`	Función `get_db()` □ conexión PDO singleton con configuración de seguridad	CRÍTICO
`admin/auth_guard.php`	Guard de autenticación, timeout de sesión, verificación de permisos	CRÍTICO
`admin/csrf.php`	Generación y validación de tokens CSRF criptográficos	CRÍTICO
`.htaccess`	Reglas Apache: rewrite, protección de directorios, cabeceras de seguridad	IMPORTANTE
`admin/.htaccess`	Protección adicional del directorio admin	IMPORTANTE
`composer.json`	Definición de dependencias PHP gestionadas por Composer	NORMAL

Sección 05

Base de Datos

5.1 Información General

Parámetro	Valor
Nombre de la base de datos	`difsanma_dif_cms`
Motor	MySQL 8.0.45
Charset por defecto	`utf8mb4`
Collation por defecto	`utf8mb4_unicode_ci`
Motor de tablas	InnoDB (soporte de transacciones y claves foráneas)
Número de tablas	~50 tablas (incluyendo tablas de transparencia dinámica)
Cifrado	DEFAULT ENCRYPTION='N' (cifrado a nivel de instancia desactivado)

5.2 Tablas del Sistema

5.2.1 Tabla `admin` Usuarios del Panel

Almacena las credenciales y metadatos de los usuarios con acceso al panel de administración.

Columna	Tipo	Descripción
`id`	INT AUTO_INCREMENT PK	Identificador único del usuario
`username`	VARCHAR(50) UNIQUE NOT NULL	Nombre de usuario para inicio de sesión
`password`	VARCHAR(255) NOT NULL	Hash bcrypt generado con `password_hash()`
`nombre`	VARCHAR(200)	Nombre completo del usuario
`rol`	ENUM('admin','usuario')	Rol del usuario: admin (acceso total) o usuario (acceso por permisos)
`activo`	TINYINT(1) DEFAULT 1	Estado de la cuenta: 1=activo, 0=desactivado
`created_at`	DATETIME DEFAULT CURRENT_TIMESTAMP	Fecha de creación del usuario

5.2.2 Tabla `admin_permisos` Permisos por Sección

Define qué secciones del panel puede acceder cada usuario con rol `usuario`. Los usuarios con rol `admin` tienen acceso irrestricto y no requieren registros en esta tabla.

Columna	Tipo	Descripción
`id`	INT AUTO_INCREMENT PK	Identificador único del permiso
`user_id`	INT FK ? admin.id	Usuario al que se otorga el permiso
`seccion_file`	VARCHAR(200)	Nombre del archivo PHP de la sección (ej: `noticias.php`)

Restricción: `UNIQUE KEY uq_user_seccion (user_id, seccion_file)` □ evita permisos duplicados. `ON DELETE CASCADE` elimina permisos al borrar el usuario.

5.2.3 Tabla `login_attempts` □ Intentos de Inicio de Sesión

Registra los intentos fallidos de inicio de sesión por dirección IP para implementar protección contra fuerza bruta.

Columna	Tipo	Descripción
`id`	INT AUTO_INCREMENT PK	Identificador del intento
`ip`	VARCHAR(45) NOT NULL	Dirección IP del cliente (soporta IPv4 e IPv6)
`attempted_at`	DATETIME DEFAULT CURRENT_TIMESTAMP	Timestamp del intento fallido

Índice: `KEY idx_ip_time (ip, attempted_at)` □ optimiza la consulta de conteo de intentos por IP en ventana de 15 minutos.

5.2.4 Tabla `admin_historial` □ Auditoría de Actividad

Registra todas las acciones realizadas por los administradores en el panel. Se alimenta automáticamente desde `auth_guard.php` en cada petición POST.

Columna	Tipo	Descripción
`id`	INT AUTO_INCREMENT PK	Identificador del evento
`user_id`	INT	ID del usuario que realizó la acción
`username`	VARCHAR(100)	Nombre de usuario (desnormalizado para historial)
`accion`	VARCHAR(100) NOT NULL	Tipo de acción: add, edit, delete, upload, login, etc.
`seccion`	VARCHAR(200) NOT NULL	Sección del panel donde se realizó la acción
`descripcion`	TEXT	Descripción detallada y legible de la acción
`ip`	VARCHAR(45)	Dirección IP del administrador

`dispositivo`	VARCHAR(20)	Tipo de dispositivo: pc, celular, tablet
`hostname`	VARCHAR(255)	Sistema operativo y navegador detectados del User-Agent
`created_at`	DATETIME DEFAULT CURRENT_TIMESTAMP	Timestamp del evento

5.2.5 Tablas de Sliders

`slider_principal` □ Imágenes del carrusel principal de la página de inicio (Swiper.js).

Columna	Tipo	Descripción
`id`	INT AUTO_INCREMENT PK	Identificador de la diapositiva
`imagen_path`	VARCHAR(500) NOT NULL	Ruta relativa de la imagen (ej: `uploads/images/abc.png`)
`orden`	INT DEFAULT 0	Posición en el carrusel (reordenable con SortableJS)
`activo`	TINYINT(1) DEFAULT 1	Visibilidad de la diapositiva
`created_at`	DATETIME DEFAULT CURRENT_TIMESTAMP	Fecha de subida

`slider_comunica` □ Imágenes del carrusel "DIF Comunica" (OwlCarousel2). Estructura similar a `slider_principal` con campos adicionales para mes y año de publicación.

5.2.6 Tablas de Programas Sociales

`programas` □ Catálogo de programas sociales del DIF.

Columna	Tipo	Descripción
`id`	INT AUTO_INCREMENT PK	Identificador del programa
`nombre`	VARCHAR(200) NOT NULL	Nombre completo del programa social
`imagen_path`	VARCHAR(500)	Imagen representativa del programa
`orden`	INT DEFAULT 0	Orden de presentación
`activo`	TINYINT(1) DEFAULT 1	Visibilidad en el sitio público

`programas_secciones` □ Secciones de contenido dentro de cada programa (pestañas o bloques de información).

`programas_secciones_paginas` □ Páginas de contenido HTML enriquecido (TinyMCE) dentro de cada sección de programa.

5.2.7 Tabla `tramites` □ Trámites y Servicios

Almacena la información de los trámites y servicios ofrecidos por las distintas direcciones del DIF.

Columna	Tipo	Descripción
`id`	INT AUTO_INCREMENT PK	Identificador del trámite
`slug`	VARCHAR(50) UNIQUE NOT NULL	Identificador textual: PMPNNA, DAAM, DANF, DAD, DPAF, DSJAIG
`titulo`	VARCHAR(200) NOT NULL	Nombre completo del trámite/dirección
`imagen_path`	VARCHAR(500)	Imagen representativa
`contenido`	LONGTEXT	Contenido HTML enriquecido generado con TinyMCE
`updated_at`	DATETIME ON UPDATE CURRENT_TIMESTAMP	Última actualización del contenido

`tramites_galeria` Galería de imágenes asociadas a cada trámite.

5.2.8 Tablas de Comunicación Social

`noticias_imagenes` Imágenes de noticias publicadas por el DIF. Incluye campos para título, descripción, fecha de publicación y ruta de imagen.

`galeria_albumes` Álbumes fotográficos del DIF.

Columna	Tipo	Descripción
`id`	INT AUTO_INCREMENT PK	Identificador del álbum
`nombre`	VARCHAR(200) NOT NULL	Nombre del álbum fotográfico
`fecha_album`	DATE NOT NULL	Fecha del evento fotografiado
`portada_path`	VARCHAR(500)	Imagen de portada del álbum
`activo`	TINYINT(1) DEFAULT 1	Visibilidad del álbum
`created_at`	DATETIME DEFAULT CURRENT_TIMESTAMP	Fecha de creación

`galeria_imagenes` Imágenes individuales dentro de cada álbum. Referencia a `galeria_albumes.id` mediante clave foránea.

5.2.9 Tablas de Transparencia Estática

El sistema implementa módulos de transparencia con estructura de tablas dedicadas para cada tipo de información fiscal y administrativa:

Grupo de tablas	Módulo	Descripción
`seac_bloques, seac_conceptos, seac_pdfs`	SEAC	Sistema de Evaluación y Acreditación de la Calidad. Organizado por bloques anuales, conceptos y PDFs trimestrales.
`cp_bloques, cp_titulos, cp_conceptos`	Cuenta Pública	Cuenta pública anual. Estructura jerárquica: bloque (año) ? título (módulo) ? concepto (documento).

`pa_bloques, pa_conceptos, pa_pdfs`	Presupuesto Anual	Presupuesto de egresos anual. Bloques por año con conceptos y PDFs asociados.
`pae_titulos, pae_pdfs`	PAE	Programa Anual de Evaluación. Títulos por año con PDFs adjuntos.
`mi_pdfs`	Matrices de Indicadores	Matrices de indicadores de resultados. PDFs organizados por año.
`conac_bloques, conac_conceptos, conac_pdfs`	CONAC	Consejo Nacional de Armonización Contable. Estructura similar a SEAC.
`fin_bloques, fin_conceptos`	Financiero	Información financiera institucional. Bloques anuales con conceptos y PDFs embebidos.

5.2.10 Tabla `trans_secciones` Transparencia Dinámica

Permite crear nuevas secciones de transparencia sin modificar el código fuente, reutilizando plantillas predefinidas.

Columna	Tipo	Descripción
`id`	INT AUTO_INCREMENT PK	Identificador de la sección
`nombre`	VARCHAR(300) NOT NULL	Nombre visible de la sección
`slug`	VARCHAR(200) UNIQUE NOT NULL	Identificador URL-friendly
`plantilla`	ENUM('seac','cuenta_publica','presupuesto_anual','pae','matrices','conac','financiero')	Plantilla de presentación a reutilizar
`icono`	VARCHAR(100)	Clase de Bootstrap Icons para el ícono
`activo`	TINYINT(1) DEFAULT 1	Visibilidad de la sección
`orden`	INT DEFAULT 0	Orden en el menú de transparencia

Las tablas `trans_bloques`, `trans_titulos`, `trans_conceptos` y `trans_pdfs` almacenan el contenido de las secciones dinámicas con relaciones de clave foránea en cascada.

5.2.11 Otras Tablas del Sistema

Tabla	Descripción
`presidencia`	Información de la presidenta del DIF: nombre, apellidos, cargo, fotografía, mensaje institucional (HTML TinyMCE)
`direcciones`	Directores y jefes de área del DIF: nombre, apellidos, cargo, área, fotografía
`organigrama`	Imagen del organigrama institucional con metadatos
`autismo_config`	Configuración de la página de la Unidad de Autismo: contenido HTML, imágenes, información de contacto

`voluntariado_config`	Configuración de la página de voluntariado: texto, formulario de registro
`voluntariado_imagenes`	Galería de imágenes de la sección de voluntariado
`footer_config`	Configuración del pie de página: dirección, teléfono, correo, redes sociales
`footer_links`	Enlaces del pie de página organizados por columnas
`contacto_config`	Información de contacto institucional: dirección, teléfono, horarios, mapa
`avisos_privacidad`	Documentos de aviso de privacidad: título, contenido HTML, fecha de publicación
`avisos_privacidad_config`	Configuración general de la sección de avisos de privacidad
`servicios_galeria`	Galería de imágenes de la sección de servicios
`institucion_banner`	Banner institucional de la página de inicio: imagen, texto, enlace

5.3 Convenciones de Nomenclatura

- **Nombres de tablas:** `snake_case` en plural o con sufijo descriptivo (ej: `galeria_albumes`, `footer_links`)
- **Claves primarias:** Siempre `id INT AUTO_INCREMENT PRIMARY KEY`
- **Claves foráneas:** Sufijo `_id` (ej: `user_id`, `album_id`, `seccion_id`)
- **Campos booleanos:** `TINYINT(1)` con nombre descriptivo (ej: `activo`, `visible`)
- **Timestamps:** `created_at DATETIME DEFAULT CURRENT_TIMESTAMP` y `updated_at DATETIME ON UPDATE CURRENT_TIMESTAMP`
- **Rutas de archivos:** Siempre rutas relativas desde la raíz del proyecto (ej: `uploads/images/archivo.jpg`)
- **Contenido HTML:** Tipo `LONGTEXT` para contenido generado por TinyMCE
- **Slugs URL:** `VARCHAR` con restricción `UNIQUE KEY`

Sección 06

Seguridad

Aviso de Seguridad

Esta sección describe los mecanismos de seguridad implementados. La información aquí contenida es de uso interno exclusivo. No debe compartirse con personal no autorizado.

6.1 Autenticación Basada en Sesiones PHP

El sistema utiliza sesiones PHP nativas para gestionar la autenticación de los administradores. El flujo de autenticación es el siguiente:

1. El usuario envía credenciales (usuario + contraseña) mediante POST con token CSRF.
2. Se verifica el token CSRF antes de procesar cualquier dato.
3. Se consulta la tabla `admin` por el `username` proporcionado.
4. La contraseña se verifica con `password_verify($password, $hash)` contra el hash bcrypt almacenado.
5. Si la autenticación es exitosa, se regenera el ID de sesión con `session_regenerate_id(true)` para prevenir session fixation.
6. Se establecen las variables de sesión: `$_SESSION['admin_logged']`, `$_SESSION['admin_id']`, `$_SESSION['admin_username']`, `$_SESSION['admin_rol']`.
7. Se registra el evento de login en `admin_historial`.

```
// Verificación de contraseña con bcrypt
if ($admin && password_verify($password, $admin['password'])) {
    session_regenerate_id(true);
    $_SESSION['admin_logged'] = true;
    $_SESSION['admin_id']     = (int) $admin['id'];
    $_SESSION['admin_rol']    = $admin['rol'] ?? 'admin';
    header('Location: dashboard');
    exit;
}
```

6.2 Protección CSRF (Cross-Site Request Forgery)

Todos los formularios del panel de administración incluyen un token CSRF criptográficamente seguro. La implementación en `admin/csrf.php` utiliza las siguientes características:

- **Generación:** `bin2hex(random_bytes(32))` □ 64 caracteres hexadecimales, 256 bits de entropía.
- **Almacenamiento:** Array de hasta 10 tokens en `$_SESSION['csrf_tokens']` para soportar múltiples pestañas abiertas simultáneamente.
- **Validación:** `hash_equals($stored, $token)` □ comparación en tiempo constante para prevenir ataques de timing.
- **Consumo:** El token se elimina del array tras su uso (parámetro `$consume = true`).

- **Rotación:** Se genera un nuevo token en cada carga de formulario.

```
// Generación de token CSRF
function csrf_token(): string {
    $token = bin2hex(random_bytes(32));
    $_SESSION['csrf_tokens'][] = $token;
    if (count($_SESSION['csrf_tokens']) > 10) {
        array_shift($_SESSION['csrf_tokens']); // FIFO: eliminar el más antiguo
    }
    return $token;
}

// Validación con comparación en tiempo constante
function csrf_validate(string $token, bool $consume = true): bool {
    foreach ($_SESSION['csrf_tokens'] as $i => $stored) {
        if (hash_equals($stored, $token)) {
            if ($consume) unset($_SESSION['csrf_tokens'][$i]);
            return true;
        }
    }
    return false;
}
```

6.3 Protección contra Fuerza Bruta

El sistema implementa rate limiting basado en dirección IP para el formulario de inicio de sesión:

- Se registra cada intento fallido en la tabla `login_attempts` con la IP y timestamp.
- Antes de procesar las credenciales, se cuenta el número de intentos fallidos de la IP en los últimos 15 minutos.
- Si el contador supera 5 intentos, se bloquea el acceso durante 15 minutos con mensaje de error genérico.
- Los intentos fallidos también se registran en `logs/login_attempts.log` para auditoría.

```
// Rate limiting: máximo 5 intentos por IP en 15 minutos
$stmtRate = $pdo->prepare(
    'SELECT COUNT(*) FROM login_attempts
     WHERE ip = ? AND attempted_at > DATE_SUB(NOW(), INTERVAL 15 MINUTE)'
);
$stmtRate->execute([$ip]);
$attempts = (int) $stmtRate->fetchColumn();
if ($attempts >= 5) {
    $error = 'Demasiados intentos fallidos. Espere 15 minutos.';
}
```

6.4 Auto-Logout por Inactividad

El sistema implementa cierre de sesión automático por inactividad en dos niveles:

- **Nivel PHP (servidor):** `auth_guard.php` verifica que el tiempo transcurrido desde `$_SESSION['last_activity']` no supere 300 segundos (5 minutos). Si se supera, destruye la sesión y redirige a `login?expired=1`.
- **Nivel JavaScript (cliente):** El sidebar incluye un timer JavaScript de 5 minutos que se reinicia con cualquier evento de usuario (mousemove, keydown, click, scroll, touchstart). Al expirar, redirige a `login.php?expired=1`.

6.5 Sistema de Permisos por Sección

Los usuarios con rol `usuario` solo pueden acceder a las secciones del panel para las que tienen un registro en `admin_permisos`. La verificación se realiza en `auth_guard.php`:

```
// Verificar permiso para la sección actual
$stmt_guard = $pdo->prepare(
    'SELECT id FROM admin_permisos WHERE user_id = ? AND seccion_file = ?'
);
$stmt_guard->execute([$_SESSION['admin_id'], $current_admin_file_guard]);
if (!$stmt_guard->fetch()) {
    header('Location: dashboard'); // Denegar acceso
    exit;
}
```

6.6 Protección contra SQL Injection

El sistema utiliza exclusivamente sentencias preparadas PDO con parámetros enlazados (`?` o `:nombre`) para todas las consultas a la base de datos. La opción `PDO::ATTR_EMULATE_PREPARES => false` garantiza que las sentencias preparadas sean nativas del motor MySQL, no emuladas por PHP, lo que proporciona protección real contra inyección SQL.

```
// Ejemplo de consulta segura con PDO
$stmt = $pdo->prepare('SELECT id, username, password FROM admin WHERE username = ? LIMIT 1');
$stmt->execute([$username]);
$admin = $stmt->fetch(); // Nunca se concatena $username directamente en el SQL
```

6.7 Protección contra XSS (Cross-Site Scripting)

El sistema aplica las siguientes medidas contra XSS:

- **Salida HTML:** Todos los datos dinámicos se escapan con `htmlspecialchars($valor, ENT_QUOTES, 'UTF-8')` antes de renderizarse en HTML.
- **Contenido TinyMCE:** El contenido HTML generado por el editor se almacena tal cual en la base de datos y se renderiza sin escapar solo en contextos donde se espera HTML (usando `echo $contenido` directamente). Se confía en que TinyMCE sanitiza el input del editor.
- **Respuestas JSON:** Los datos en respuestas AJAX se codifican con `json_encode()` que escapa caracteres especiales por defecto.

6.8 Gestión Segura de Subida de Archivos

El módulo `admin/upload_handler.php` implementa un proceso de validación multicapa:

1. Verificación del código de error PHP (`UPLOAD_ERR_OK`)

2. Validación de tamaño máximo (20 MB imágenes, 50 MB PDFs)
3. Validación de extensión de archivo contra lista blanca
4. Validación del tipo MIME real con `finfo_file()` (no confía en el MIME declarado por el cliente)
5. Generación de nombre de archivo sanitizado (sin caracteres peligrosos)
6. Uso de `move_uploaded_file()` (función segura de PHP para archivos subidos)
7. Compresión y redimensionamiento automático de imágenes con GD Library

6.9 Protección del Directorio Admin con .htaccess

El directorio `admin/` cuenta con un archivo `.htaccess` que proporciona una capa adicional de protección a nivel de servidor Apache, complementando la autenticación PHP.

6.10 Cabeceras de Seguridad HTTP

Se recomienda configurar las siguientes cabeceras HTTP en el `.htaccess` raíz para reforzar la seguridad del sitio:

```
Header always set X-Content-Type-Options "nosniff"
Header always set X-Frame-Options "SAMEORIGIN"
Header always set X-XSS-Protection "1; mode=block"
Header always set Referrer-Policy "strict-origin-when-cross-origin"
Header always set Permissions-Policy "geolocation=(), microphone=(), camera=()"
```

6.11 Consideraciones de Seguridad Adicionales

Las siguientes prácticas de seguridad están implementadas o se recomiendan para el entorno de producción:

Protección del archivo config.php

El archivo `config.php` contiene credenciales de base de datos y debe protegerse de acceso público. El comentario en el archivo indica que debe moverse fuera del webroot en producción. Como medida alternativa, se puede agregar la siguiente regla en `.htaccess`:

```
<Files "config.php">
    Order allow,deny
    Deny from all
</Files>
```

Protección del directorio uploads/

El directorio `uploads/` almacena archivos subidos por los administradores. Para prevenir la ejecución de scripts PHP maliciosos que pudieran subirse, se recomienda agregar un `.htaccess` en ese directorio:

```
# uploads/.htaccess  Prevenir ejecución de PHP en uploads
<FilesMatch "\.php$">
    Order allow,deny
    Deny from all
```

```
</FilesMatch>
Options -ExecCGI
AddHandler cgi-script .php .pl .py .jsp .asp .sh .cgi
```

Enumeración de usuarios

El mensaje de error del formulario de login es genérico ("Usuario o contraseña incorrectos") y no revela si el usuario existe o no en la base de datos. Esto previene la enumeración de usuarios válidos del sistema.

Protección contra clickjacking

La cabecera `X-Frame-Options: SAMEORIGIN` previene que el sitio sea embebido en un iframe de otro dominio, protegiendo contra ataques de clickjacking donde un atacante superpone el sitio legítimo sobre una página maliciosa.

Validación de entradas en el servidor

Todas las entradas del usuario se validan y sanitizan en el servidor PHP, independientemente de cualquier validación del lado del cliente (JavaScript). Las validaciones del cliente son solo para mejorar la experiencia de usuario, nunca como medida de seguridad.

- Campos numéricos: `(int)$_POST['id']` → conversión explícita a entero
- Campos de texto: `trim(htmlspecialchars($_POST['titulo']))` → eliminación de espacios y escape HTML
- Campos de fecha: validación de formato con `DateTime::createFromFormat()`
- Slugs: `preg_replace('/[^a-z0-9\-]/', '', strtolower($slug))` → solo caracteres URL-seguros

Resumen de la Postura de Seguridad

Vector de Ataque	Mitigación Implementada	Estado
SQL Injection	PDO con sentencias preparadas nativas	Mitigado
XSS	htmlspecialchars() en toda salida dinámica	Mitigado
CSRF	Tokens criptográficos por formulario con hash_equals()	Mitigado
Fuerza bruta	Rate limiting: 5 intentos / 15 min por IP	Mitigado
Session fixation	session_regenerate_id(true) tras login	Mitigado
Session hijacking	Timeout de inactividad 5 min (PHP + JS)	Mitigado
Upload malicioso	Validación MIME real con finfo, lista blanca de extensiones	Mitigado
Acceso no autorizado	auth_guard.php en todas las páginas admin	Mitigado
Escalada de privilegios	Verificación de rol en cada operación sensible	Mitigado
Clickjacking	X-Frame-Options: SAMEORIGIN (recomendado)	Recomendado

Ejecución de scripts en uploads	.htaccess en uploads/ (recomendado)	Recomendado
Exposición de config.php	Mover fuera del webroot (recomendado)	Recomendado

Sección 07

Módulos del Sistema

7.1 Módulo: Slider Principal

Archivo: `admin/slider_principal.php` | **Tabla:** `slider_principal`

Gestiona las imágenes del carrusel principal de la página de inicio, implementado con Swiper.js. Permite subir nuevas imágenes, activar/desactivar diapositivas y reordenarlas mediante drag & drop con SortableJS.

Acción POST	Descripción
`upload`	Sube una nueva imagen al slider. Llama a `handle_upload($_FILES['imagen'], 'image')` e inserta en BD.
`toggle`	Activa o desactiva una diapositiva (`activo = 1|0`).
`delete`	Elimina la diapositiva y el archivo físico del servidor.
`reorder`	Actualiza el campo `orden` de múltiples registros según el array JSON enviado por SortableJS.

7.2 Módulo: Slider DIF Comunica

Archivo: `admin/slider_comunica.php` | **Tabla:** `slider_comunica`

Gestiona el carrusel de la sección "DIF Comunica" (OwlCarousel2). Similar al slider principal pero con campos adicionales para mes y año de publicación, permitiendo organizar el contenido cronológicamente.

7.3 Módulo: Programas Sociales

Archivos: `admin/programas.php` , `admin/programa_editar.php` | **Tablas:** `programas` , `programas_secciones` , `programas_secciones_paginas`

Módulo jerárquico de tres niveles para gestionar los programas sociales del DIF. El nivel superior (`programas`) define el catálogo de programas con imagen y orden. Cada programa puede tener múltiples secciones (`programas_secciones`), y cada sección puede contener múltiples páginas de contenido HTML enriquecido (`programas_secciones_paginas`) editadas con TinyMCE.

7.4 Módulo: Trámites y Servicios

Archivo: `admin/tramites.php` | **Tablas:** `tramites` , `tramites_galeria`

Gestiona la información de los 6 trámites/direcciones del DIF (PMPNNA, DAAM, DANF, DAD, DPAF, DSJAIG). Cada trámite tiene un slug fijo que lo identifica en la URL pública. El contenido se edita con TinyMCE y puede incluir una galería de imágenes asociada.

7.5 Módulo: Noticias

Archivo: `admin/noticias.php` | **Tabla:** `noticias_imagenes`

Permite publicar noticias institucionales con imagen, título, descripción y fecha. Las noticias se muestran en la sección "Comunicación Social" del sitio público con Lightbox2 para visualización de imágenes.

7.6 Módulo: Galería Fotográfica

Archivo: `admin/galeria.php` | **Tablas:** `galeria_albumes`, `galeria_imagenes`

Sistema de álbumes fotográficos con dos niveles: álbum (con portada y fecha) e imágenes individuales dentro del álbum. Soporta subida múltiple de imágenes. El sitio público muestra los álbumes con Lightbox2 para visualización en modal.

Acción POST	Descripción
`create_album`	Crea un nuevo álbum con nombre, fecha y portada
`edit_album`	Modifica nombre, fecha y portada de un álbum existente
`delete_album`	Elimina el álbum y todas sus imágenes (archivos físicos incluidos)
`add_image`	Agrega una imagen a un álbum existente
`delete_image`	Elimina una imagen del álbum y su archivo físico

7.7 Módulo: Presidencia

Archivo: `admin/presidencia.php` | **Tabla:** `presidencia`

Gestiona la información de la presidenta del DIF: nombre, apellidos, cargo, fotografía y mensaje institucional en HTML enriquecido (TinyMCE). La página pública `acerca-del-dif/presidencia.php` consume estos datos.

7.8 Módulo: Direcciones

Archivo: `admin/direcciones.php` | **Tabla:** `direcciones`

Administra el directorio de directores y jefes de área del DIF. Permite agregar, editar y eliminar registros con nombre, apellidos, cargo, área y fotografía. Soporta reordenamiento con SortableJS.

7.9 Módulo: Organigrama

Archivo: `admin/organigrama.php` | **Tabla:** `organigrama`

Permite subir y actualizar la imagen del organigrama institucional. La imagen se muestra en la página pública `acerca-del-dif/organigrama.php`.

7.10 Módulo: Voluntariado

Archivo: `admin/voluntariado.php` | **Tablas:** `voluntariado_config`, `voluntariado_imagenes`

Gestiona la página de voluntariado del DIF: texto de presentación, formulario de registro y galería de imágenes de actividades de voluntariado.

7.11 Módulo: Unidad de Autismo

Archivo: `admin/autismo.php` | **Tabla:** `autismo_config`

Administra el contenido de la página de la Unidad de Atención al Autismo: información del servicio, horarios, contacto e imágenes. El contenido principal se edita con TinyMCE.

7.12 Módulo: Footer

Archivo: `admin/footer.php` | **Tablas:** `footer_config`, `footer_links`

Configura el pie de página del sitio público: dirección institucional, teléfono, correo electrónico, redes sociales y enlaces organizados por columnas. Los enlaces se pueden agregar, editar, eliminar y reordenar.

7.13 Módulos de Transparencia

Los módulos de transparencia (SEAC, Cuenta Pública, Presupuesto Anual, PAE, Matrices de Indicadores, CONAC, Financiero) siguen una estructura similar:

- Organización por **bloques anuales** (año fiscal)
- Dentro de cada bloque: **conceptos** o **títulos** con PDFs adjuntos
- Los PDFs se visualizan en el panel admin mediante un modal con iframe (PDF.js)
- Soporte para subida de PDFs de hasta 50 MB
- Reordenamiento de conceptos con SortableJS

7.14 Módulo: Transparencia Dinámica

Archivos: `admin/transparencia_dinamica.php`, `admin/transparencia_seccion.php`

Permite crear nuevas secciones de transparencia sin modificar el código fuente. El administrador define el nombre, slug, plantilla a reutilizar e ícono de la sección. El sistema genera automáticamente la interfaz de administración y la página pública correspondiente basándose en la plantilla seleccionada.

7.15 Módulo: Usuarios y Permisos

Archivo: `admin/usuarios.php` | **Tablas:** `admin`, `admin_permisos`

Exclusivo para usuarios con rol `admin`. Permite crear nuevos usuarios del panel, asignar roles (admin/usuario), activar/desactivar cuentas, restablecer contraseñas y gestionar los permisos de sección para usuarios con rol `usuario`.

7.16 Módulo: Historial y Reportes

Archivos: `admin/historial.php`, `admin/reportes_historial.php` | **Tabla:** `admin_historial`

Visualiza el registro completo de actividad del panel de administración con filtros por usuario, sección, tipo de acción y rango de fechas. El módulo de reportes genera estadísticas de uso del sistema.

Sección 08

API Interna / Endpoints AJAX

8.1 Patrón General de Comunicación

El sistema no implementa una API REST separada. Las operaciones AJAX se realizan mediante peticiones POST al mismo archivo PHP del módulo, diferenciadas por el campo `action` en el cuerpo del formulario. Todas las respuestas AJAX retornan JSON con la siguiente estructura base:

```
// Respuesta exitosa
{
  "success": true,
  "message": "Operación realizada correctamente",
  "data": { ... }  // Opcional: datos adicionales
}

// Respuesta de error
{
  "success": false,
  "error": "Descripción del error"
}
```

8.2 Endpoint: Reordenamiento (SortableJS)

Todos los módulos con soporte de reordenamiento utilizan el mismo patrón:

```
// Request
POST /admin/[modulo].php
Content-Type: application/x-www-form-urlencoded

action=reorder
csrf_token=[token]
order=[{"id":3,"orden":1},{"id":1,"orden":2},{"id":2,"orden":3}]

// Response
{ "success": true }
```

8.3 Endpoint: Toggle de Visibilidad

```
// Request
POST /admin/[modulo].php

action=toggle
csrf_token=[token]
```

```
id=[integer]
activo=[0|1]

// Response
{ "success": true, "activo": 1 }
```

8.4 Endpoint: Subida de Archivos

La subida de archivos se realiza mediante formularios multipart. El manejador centralizado `upload_handler.php` procesa la validación y retorna la ruta relativa del archivo guardado:

```
// Request
POST /admin/[modulo].php
Content-Type: multipart/form-data

action=upload
csrf_token=[token]
imagen=[file: JPG|PNG|WEBP, max 20MB]

// Response exitosa
{
  "success": true,
  "path": "uploads/images/nombre_archivo.jpg",
  "message": "Imagen subida correctamente"
}

// Response de error
{
  "success": false,
  "error": "El archivo supera el límite permitido de 20 MB."
}
```

8.5 Endpoint: Subida de PDF

```
// Request
POST /admin/[modulo_transparencia].php
Content-Type: multipart/form-data

action=upload_pdf
csrf_token=[token]
concepto_id=[integer]
pdf=[file: PDF, max 50MB]
titulo=[string]

// Response
{
  "success": true,
  "path": "uploads/pdfs/nombre_documento.pdf",
```

```
  "id": 42
}
```

8.6 Endpoint: Eliminación de Registros

```
// Request
POST /admin/[modulo].php

action=delete
csrf_token=[token]
id=[integer]

// Response
{ "success": true, "message": "Registro eliminado correctamente" }
```

8.7 Manejo de Errores

El sistema maneja los siguientes tipos de errores en las respuestas AJAX:

Tipo de Error	Código HTTP	Descripción
Token CSRF inválido	200 (JSON error)	`{"success":false,"error":"Token de seguridad inválido"}`
Sesión expirada	302 Redirect	Redirige a `login?expired=1`
Sin permisos	302 Redirect	Redirige a `dashboard`
Error de validación	200 (JSON error)	`{"success":false,"error":"[descripción]"}`
Error de base de datos	200 (JSON error)	Mensaje genérico en producción, detalle en debug
Error de subida	200 (JSON error)	Mensaje descriptivo del error de PHP upload

Nota sobre CSRF en AJAX

Todas las peticiones AJAX que modifican datos deben incluir el campo `csrf_token` en el cuerpo de la petición. El token se obtiene del campo oculto del formulario HTML o de la variable PHP `$csrf` generada al cargar la página.

Sección 09

Sistema de Autenticación y Autorización

9.1 Flujo Completo de Login

9.2 Variables de Sesión

Variable	Tipo	Descripción
`$_SESSION['admin_logged']`	bool	Indicador de sesión activa. Debe ser `true` para acceder al panel.
`$_SESSION['admin_id']`	int	ID del usuario autenticado en la tabla `admin`.
`$_SESSION['admin_username']`	string	Nombre de usuario para mostrar en la interfaz y registrar en historial.
`$_SESSION['admin_rol']`	string	Rol del usuario: `'admin'` o `'usuario'`.
`$_SESSION['last_activity']`	int	Timestamp Unix de la última actividad. Actualizado en cada request por `auth_guard.php`.
`$_SESSION['csrf_tokens']`	array	Array de tokens CSRF activos (máximo 10).
`$_SESSION['flash_message']`	string	Mensaje flash para mostrar en la siguiente página (éxito/error).
`$_SESSION['flash_type']`	string	Tipo del mensaje flash: `'success'`, `'danger'`, `'warning'`.

9.3 Roles de Usuario

Rol	Acceso	Restricciones
`admin`	Acceso total a todas las secciones del panel	Ninguna. Puede gestionar usuarios y permisos.
`usuario`	Acceso solo a secciones con registro en `admin_permisos`	No puede acceder al módulo de usuarios. No puede ver el historial completo.

9.4 Proceso de Cierre de Sesión

El archivo `admin/logout.php` realiza el cierre de sesión de forma segura:

```
// admin/logout.php
session_start();
// Registrar logout en historial antes de destruir la sesión
registrar_historial($pdo, 'logout', 'Sistema', 'Cierre de sesión: ' . $_SESSION['admin_username']);
// Limpiar todas las variables de sesión
session_unset();
```

```
// Destruir la sesión del servidor
session_destroy();
// Redirigir al login
header('Location: login');
exit;
```

9.5 Gestión de Contraseñas

Las contraseñas se almacenan exclusivamente como hashes bcrypt generados con `password_hash($password, PASSWORD_DEFAULT)`. PHP 8 utiliza bcrypt con factor de costo 10 por defecto. La verificación se realiza con `password_verify($input, $hash)`.

El módulo de usuarios permite al administrador restablecer la contraseña de cualquier usuario. El nuevo hash se genera en el servidor; nunca se almacena ni transmite la contraseña en texto plano.

Buena práctica implementada

El sistema utiliza `session_regenerate_id(true)` tras el login exitoso para prevenir ataques de session fixation. El parámetro `true` elimina la sesión anterior del servidor.

Sección 10

Gestión de Archivos

10.1 Proceso de Subida de Imágenes

Toda subida de archivos pasa por la función centralizada `handle_upload(array $file, string $type)` en `admin/upload_handler.php`. El proceso completo es:

1. **Verificación de error PHP:** Se comprueba que `$file['error'] === UPLOAD_ERR_OK`.
2. **Validación de tamaño:** Imágenes: máximo 20 MB (`UPLOAD_MAX_IMAGE_MB`). PDFs: máximo 50 MB (`UPLOAD_MAX_PDF_MB`).
3. **Validación de extensión:** Lista blanca: `jpg, jpeg, png, webp` para imágenes; `pdf` para documentos.
4. **Validación MIME real:** `finfo_file($finfo, $file['tmp_name'])` detecta el tipo MIME real del archivo, independientemente de la extensión declarada.
5. **Sanitización del nombre:** Se eliminan caracteres peligrosos con `preg_replace('/[^a-zA-Z0-9_\-\. áéíóúñÁÉÍÓÚÑ]/', '_', $baseName)`.
6. **Resolución de conflictos:** Si ya existe un archivo con el mismo nombre, se agrega un sufijo numérico incremental.
7. **Creación de directorio:** Si el directorio de destino no existe, se crea con `mkdir($destDir, 0755, true)`.
8. **Movimiento seguro:** `move_uploaded_file($file['tmp_name'], $destPath)`.
9. **Compresión automática:** Las imágenes se comprimen y redimensionan con GD Library (máx. 1920px de ancho, JPEG/WEBP al 85% de calidad, PNG compresión nivel 6).

10.2 Estructura de Directorios de Uploads

```
uploads/ +-- images/ # Imágenes subidas (JPG, PNG, WEBP) ¦ +-- abc123def456.jpg # Nombre sanitizado del archivo original ¦ +--
... +-- pdfs/ # Documentos PDF subidos +-- Cuenta_Publica_2024.pdf +-- ...
```

10.3 Nomenclatura de Archivos

Tipo	Nomenclatura	Ejemplo
Imágenes	Nombre original sanitizado (sin caracteres especiales peligrosos). Si hay conflicto, se agrega sufijo `_N`.	`foto_evento.jpg`, `foto_evento_1.jpg`
PDFs	Nombre original sanitizado. Si hay conflicto, se agrega sufijo `_N`.	`Cuenta_Publica_2024.pdf`

10.4 Compresión Automática de Imágenes

La función `_compress_image(string $path, string $mime)` procesa las imágenes tras la subida:

Formato	Calidad / Compresión	Ancho máximo	Transparencia
JPEG	85%	1920px	No aplica
PNG	Nivel 6 (de 9)	1920px	Preservada (alpha channel)
WEBP	85%	1920px	Preservada

Si la imagen es más pequeña que 1920px de ancho, no se redimensiona. Si la compresión falla por cualquier razón, la imagen original queda intacta y el error se registra en `logs/upload_errors.log`.

10.5 Eliminación de Archivos

Al eliminar un registro que referencia un archivo (imagen o PDF), el sistema elimina también el archivo físico del servidor usando `unlink(BASE_PATH . '/' . $registro['imagen_path'])`. Se verifica que el archivo exista antes de intentar eliminarlo para evitar errores.

10.6 Logs del Sistema

Archivo de Log	Contenido
`logs/upload_errors.log`	Errores de subida y compresión de archivos con timestamp
`logs/login_attempts.log`	Intentos fallidos de inicio de sesión con IP y usuario intentado

Seguridad del directorio logs/

El directorio `logs/` debe estar protegido con `.htaccess` para impedir el acceso público a los archivos de log. Agregar: `Deny from all` en `logs/.htaccess`.

Sección 11

Configuración del Sistema

11.1 Archivo config.php

El archivo `config.php` en la raíz del proyecto define todas las constantes globales del sistema. Las credenciales de base de datos se leen primero de variables de entorno del servidor; si no existen, se usan los valores definidos en el archivo como fallback.

```php
<?php
// -- Base de datos -------------------------------------------------------
define('DB_HOST', getenv('DB_HOST') ?: 'localhost');
define('DB_NAME', getenv('DB_NAME') ?: 'difsanma_dif_cms');
define('DB_USER', getenv('DB_USER') ?: 'root');
define('DB_PASS', getenv('DB_PASS') ?: 'Pa55worD');

// -- Entorno -------------------------------------------------------------
// true  ? muestra errores detallados (solo en desarrollo)
// false ? errores genéricos al usuario, detalles solo en logs
define('APP_DEBUG', (bool)(getenv('APP_DEBUG') ?: false));

// -- Límites de subida de archivos ---------------------------------------
define('UPLOAD_MAX_IMAGE_MB', 20);  // Máximo para imágenes (JPG, PNG, WEBP)
define('UPLOAD_MAX_PDF_MB',  50);   // Máximo para PDFs

// -- Rutas base ----------------------------------------------------------
define('BASE_PATH',    __DIR__);
define('UPLOADS_PATH', BASE_PATH . '/uploads');
define('LOGS_PATH',    BASE_PATH . '/logs');
```

11.2 Constantes del Sistema

Constante	Tipo	Valor por defecto	Descripción
`DB_HOST`	string	`'localhost'`	Host del servidor MySQL
`DB_NAME`	string	`'difsanma_dif_cms'`	Nombre de la base de datos
`DB_USER`	string	`'root'`	Usuario de MySQL
`DB_PASS`	string	`'Pa55worD'`	Contraseña de MySQL
`APP_DEBUG`	bool	`false`	Modo debug: muestra errores detallados
`UPLOAD_MAX_IMAGE_MB`	int	`20`	Tamaño máximo de imágenes en MB

`UPLOAD_MAX_PDF_MB`	int	`50`	Tamaño máximo de PDFs en MB
`BASE_PATH`	string	`__DIR__`	Ruta absoluta de la raíz del proyecto
`UPLOADS_PATH`	string	`BASE_PATH . '/uploads'`	Ruta absoluta del directorio de uploads
`LOGS_PATH`	string	`BASE_PATH . '/logs'`	Ruta absoluta del directorio de logs

11.3 Variables de Entorno

En producción, se recomienda definir las credenciales de base de datos como variables de entorno del servidor en lugar de hardcodearlas en `config.php`. En cPanel, esto se puede configurar en la sección "Variables de entorno" o mediante el archivo `.env` del servidor.

Variable de Entorno	Descripción
`DB_HOST`	Host del servidor MySQL de producción
`DB_NAME`	Nombre de la base de datos de producción
`DB_USER`	Usuario MySQL con permisos SELECT, INSERT, UPDATE, DELETE
`DB_PASS`	Contraseña del usuario MySQL
`APP_DEBUG`	Establecer en `false` en producción

11.4 Configuración de Sesiones PHP

Las sesiones PHP se configuran con los valores por defecto del servidor. Para mayor seguridad en producción, se recomienda agregar las siguientes directivas en `php.ini` o `.htaccess`:

```
; php.ini recomendado para producción
session.cookie_httponly = 1      ; Previene acceso JavaScript a la cookie de sesión
session.cookie_secure   = 1      ; Solo enviar cookie por HTTPS
session.use_strict_mode = 1      ; Rechazar IDs de sesión no inicializados
session.gc_maxlifetime  = 1800   ; Tiempo de vida de sesión: 30 minutos
session.cookie_samesite = Strict ; Protección CSRF adicional a nivel de cookie
```

11.5 Configuración de PHP para Subida de Archivos

El servidor debe tener configurados los siguientes valores en `php.ini` para soportar los límites de subida del sistema:

```
upload_max_filesize = 50M    ; Debe ser >= UPLOAD_MAX_PDF_MB
post_max_size       = 55M    ; Debe ser > upload_max_filesize
max_execution_time  = 120    ; Tiempo suficiente para procesar PDFs grandes
memory_limit        = 256M   ; Suficiente para GD Library con imágenes grandes
```

11.6 Configuración de Apache (.htaccess)

El archivo `.htaccess` raíz configura las reglas de reescritura de URLs y las cabeceras de seguridad:

```
# Habilitar mod_rewrite
RewriteEngine On

# Redirigir a HTTPS (descomentar en producción)
# RewriteCond %{HTTPS} off
# RewriteRule ^(.*)$ https://%{HTTP_HOST}%{REQUEST_URI} [L,R=301]

# Proteger archivos de configuración
<FilesMatch "^(config\.php|composer\.(json|lock))$">
    Order allow,deny
    Deny from all
</FilesMatch>

# Proteger directorio logs
<IfModule mod_rewrite.c>
    RewriteRule ^logs/ - [F,L]
</IfModule>

# Cabeceras de seguridad
Header always set X-Content-Type-Options "nosniff"
Header always set X-Frame-Options "SAMEORIGIN"
```

Sección 12

Instalación y Despliegue

12.1 Requisitos del Servidor

Componente	Versión mínima	Recomendada
PHP	8.0	8.2 o superior
MySQL	8.0	8.0.45
Apache	2.4	2.4 con mod_rewrite
Espacio en disco	500 MB	2 GB (para uploads)
RAM del servidor	512 MB	1 GB o más
Extensiones PHP	pdo, pdo_mysql, gd, fileinfo, mbstring, session, json, openssl	

12.2 Instalación Local con XAMPP

1. Descargar e instalar XAMPP con PHP 8.x desde `apachefriends.org`.
2. Copiar el directorio del proyecto a `C:\xampp\htdocs\dif-cms\`.
3. Iniciar los servicios Apache y MySQL desde el panel de control de XAMPP.
4. Abrir phpMyAdmin en `http://localhost/phpmyadmin`.
5. Crear la base de datos `difsanma_dif_cms` con charset `utf8mb4_unicode_ci`.
6. Importar el archivo `database/schema.sql` para crear todas las tablas.
7. Importar `database/seed.sql` para datos iniciales (usuario admin).
8. Verificar que `config.php` tenga las credenciales correctas (`DB_USER=root`, `DB_PASS=''` para XAMPP por defecto).
9. Crear los directorios `uploads/images/`, `uploads/pdfs/` y `logs/` con permisos de escritura.
10. Acceder al panel en `http://localhost/dif-cms/admin/login`.

```
# Crear directorios necesarios (PowerShell en Windows)
mkdir C:\xampp\htdocs\dif-cms\uploads\images
mkdir C:\xampp\htdocs\dif-cms\uploads\pdfs
mkdir C:\xampp\htdocs\dif-cms\logs
```

12.3 Despliegue en Hosting cPanel

1. Acceder al panel cPanel del hosting.

2. Crear la base de datos MySQL desde "Bases de datos MySQL" en cPanel.
3. Crear un usuario MySQL y asignarle todos los privilegios sobre la base de datos.
4. Importar el esquema SQL desde phpMyAdmin del hosting.
5. Subir los archivos del proyecto al directorio `public_html/` (o subdirectorio) mediante FTP o el Administrador de Archivos de cPanel.
6. Actualizar `config.php` con las credenciales de producción, o configurar las variables de entorno en cPanel.
7. Verificar que los directorios `uploads/` y `logs/` tengan permisos `755` o `775`.
8. Verificar que `mod_rewrite` esté habilitado en el hosting.
9. Cambiar `APP_DEBUG` a `false` en producción.
10. Probar el acceso al panel en `https://dominio.com/admin/login`.

12.4 Checklist de Despliegue

☐	Tarea	Prioridad
☐	Base de datos creada con charset utf8mb4_unicode_ci	CRÍTICO
☐	Esquema SQL importado correctamente (todas las tablas)	CRÍTICO
☐	Credenciales de BD actualizadas en config.php o variables de entorno	CRÍTICO
☐	APP_DEBUG = false en producción	CRÍTICO
☐	Directorios uploads/ y logs/ con permisos de escritura	CRÍTICO
☐	mod_rewrite habilitado en Apache	IMPORTANTE
☐	Extensiones PHP requeridas habilitadas	IMPORTANTE
☐	Límites de subida PHP configurados (upload_max_filesize=50M)	IMPORTANTE
☐	HTTPS configurado y certificado SSL activo	IMPORTANTE
☐	Contraseña del usuario admin cambiada desde la predeterminada	IMPORTANTE
☐	Acceso al panel de administración verificado	NORMAL
☐	Subida de imágenes y PDFs probada	NORMAL
☐	Sitio público verificado en múltiples navegadores	NORMAL
☐	Respaldo inicial de la base de datos realizado	NORMAL

12.5 Importación de la Base de Datos

El directorio `database/` contiene los scripts SQL individuales por tabla. Para una instalación limpia, se recomienda usar el archivo consolidado:

```
# Importar esquema completo desde línea de comandos MySQL
mysql -u root -p difsanma_dif_cms < database/schema.sql

# O desde phpMyAdmin:
# 1. Seleccionar la base de datos
# 2. Pestaña "Importar"
# 3. Seleccionar database/schema.sql
# 4. Clic en "Continuar"
```

Sección 13

Mantenimiento y Respaldos

13.1 Estrategia de Respaldos

Se recomienda implementar una estrategia de respaldos en dos niveles: base de datos y archivos del sistema. Los respaldos deben almacenarse en una ubicación externa al servidor de producción (almacenamiento en la nube, disco externo o servidor secundario).

13.2 Respaldo de Base de Datos

Frecuencia recomendada: Diaria (automática) + manual antes de cualquier actualización.

```
# Respaldo completo de la base de datos con mysqldump
mysqldump -u [usuario] -p[contraseña] \
  --single-transaction \
  --routines \
  --triggers \
  difsanma_dif_cms > respaldo_$(date +%Y%m%d_%H%M%S).sql

# Comprimir el respaldo
gzip respaldo_$(date +%Y%m%d_%H%M%S).sql
```

En cPanel, el respaldo de base de datos se puede automatizar desde la sección "Cron Jobs" con el siguiente comando:

```
# Cron job diario a las 2:00 AM
0 2 * * * mysqldump -u usuario -pcontraseña difsanma_dif_cms | gzip > /home/usuario/backups/db_$(date +\%Y\%m\%d).sql.gz
```

13.3 Respaldo de Archivos

Frecuencia recomendada: Semanal para archivos estáticos, diaria para el directorio `uploads/`.

Los directorios críticos a respaldar son:

- `uploads/` □ Imágenes y PDFs subidos por los administradores (contenido dinámico)
- `config.php` □ Configuración del sistema
- Código fuente completo del proyecto (si se realizaron modificaciones)

```
# Respaldo del directorio uploads con tar
tar -czf uploads_$(date +%Y%m%d).tar.gz uploads/

# Respaldo completo del proyecto (excluir node_modules y .git)
tar -czf dif-cms_$(date +%Y%m%d).tar.gz \
  --exclude='.git' \
```

```
  --exclude='node_modules' \
  /ruta/al/proyecto/
```

13.4 Procedimiento de Restauración

1. Detener el acceso al sitio (opcional: activar página de mantenimiento).
2. Restaurar la base de datos desde el respaldo SQL:

```
# Restaurar base de datos
mysql -u [usuario] -p[contraseña] difsanma_dif_cms < respaldo_YYYYMMDD.sql
```

3. Restaurar el directorio `uploads/` desde el respaldo tar.
4. Verificar permisos de directorios (`uploads/` y `logs/` deben ser escribibles).
5. Probar el acceso al panel de administración y al sitio público.
6. Verificar que las imágenes y PDFs se muestren correctamente.

13.5 Mantenimiento Preventivo

Tarea	Frecuencia	Descripción
Limpiar tabla login_attempts	Mensual	`DELETE FROM login_attempts WHERE attempted_at < DATE_SUB(NOW(), INTERVAL 30 DAY)`
Archivar historial antiguo	Trimestral	Exportar y eliminar registros de `admin_historial` con más de 6 meses de antigüedad
Verificar espacio en disco	Semanal	Monitorear el crecimiento del directorio `uploads/`
Revisar logs de errores	Semanal	Revisar `logs/upload_errors.log` y `logs/login_attempts.log`
Actualizar contraseñas	Semestral	Cambiar contraseñas de usuarios del panel y de la base de datos
Verificar certificado SSL	Mensual	Asegurar que el certificado SSL no esté próximo a vencer
Optimizar tablas MySQL	Mensual	`OPTIMIZE TABLE admin_historial, galeria_imagenes, noticias_imagenes`

13.6 Monitoreo del Sistema

Se recomienda implementar las siguientes métricas de monitoreo:

- **Disponibilidad del sitio:** Usar herramientas como UptimeRobot o Pingdom para alertas de caída.
- **Espacio en disco:** Alertas cuando el uso supere el 80% de la capacidad.
- **Intentos de login:** Revisar periódicamente `logs/login_attempts.log` para detectar ataques de fuerza bruta.
- **Errores PHP:** Configurar `error_log` en `php.ini` y revisar el log de errores de Apache.

- **Actividad del panel:** Revisar el módulo de historial para detectar actividad inusual.

Sección 14

Rendimiento y Optimización

14.1 Optimización de Imágenes

El sistema ya implementa compresión automática de imágenes con GD Library al momento de la subida. Las imágenes se redimensionan a un máximo de 1920px de ancho y se comprimen al 85% de calidad para JPEG y WEBP. Esto reduce significativamente el tamaño de los archivos sin pérdida visual perceptible.

Recomendaciones adicionales:

- Usar formato WEBP para nuevas imágenes (mejor compresión que JPEG/PNG con calidad equivalente).
- Implementar lazy loading en imágenes del sitio público con el atributo `loading="lazy"`.
- Considerar la implementación de un CDN para servir imágenes estáticas en producción.

14.2 Caché del Navegador

Configurar cabeceras de caché en `.htaccess` para reducir las peticiones al servidor:

```
<IfModule mod_expires.c>
    ExpiresActive On
    # Imágenes: 1 mes
    ExpiresByType image/jpeg "access plus 1 month"
    ExpiresByType image/png  "access plus 1 month"
    ExpiresByType image/webp "access plus 1 month"
    # CSS y JS: 1 semana
    ExpiresByType text/css        "access plus 1 week"
    ExpiresByType application/javascript "access plus 1 week"
    # Fuentes: 1 año
    ExpiresByType font/woff2 "access plus 1 year"
</IfModule>
```

14.3 Compresión GZIP

Habilitar compresión GZIP para reducir el tamaño de las respuestas HTTP:

```
<IfModule mod_deflate.c>
    AddOutputFilterByType DEFLATE text/html text/css application/javascript
    AddOutputFilterByType DEFLATE application/json text/xml
</IfModule>
```

14.4 Optimización de Consultas SQL

El sistema utiliza índices en las columnas más consultadas:

- `login_attempts` : Índice compuesto `(ip, attempted_at)` para la consulta de rate limiting.
- `admin_historial` : Índices en `created_at` y `user_id` para filtros del historial.
- `admin` : Índice único en `username` para la consulta de login.
- `trans_secciones` : Índice único en `slug` para búsqueda por URL.

Recomendaciones adicionales:

- Agregar índices en columnas `activo` y `orden` de tablas con muchos registros (sliders, programas, galería).
- Usar `LIMIT` en consultas de listado para evitar cargar todos los registros.
- Considerar implementar caché de consultas frecuentes con APCu o Memcached si el hosting lo soporta.

14.5 Optimización del Frontend

Optimización	Estado	Descripción
Bootstrap local	Implementado	Bootstrap CSS servido localmente, sin dependencia de CDN para estilos críticos
jQuery con fallback local	Implementado	jQuery cargado desde CDN con fallback a `lib/jquery/jquery.min.js`
Compresión de imágenes	Implementado	GD Library comprime automáticamente al subir
Minificación CSS/JS	Pendiente	Minificar `css/style.css` y `js/main.js` para producción
Lazy loading imágenes	Pendiente	Agregar `loading="lazy"` a imágenes de galería y noticias
Preconnect Google Fonts	Pendiente	Agregar `<link rel="preconnect" href="https://fonts.googleapis.com">`

14.6 Recomendaciones de Mejora a Futuro

- **Mover config.php fuera del webroot:** El comentario en el archivo indica que debe moverse a `/etc/dif-cms/config.php` en producción para mayor seguridad.
- **Implementar OPcache:** Habilitar PHP OPcache para cachear el bytecode compilado de PHP y reducir el tiempo de procesamiento.
- **Paginación en listados:** Implementar paginación en módulos con muchos registros (historial, galería, noticias) para mejorar el rendimiento.
- **Thumbnails automáticos:** Generar miniaturas de imágenes al momento de la subida para acelerar la carga de listados en el panel admin.
- **API REST separada:** Considerar separar la lógica de negocio en una API REST para facilitar el mantenimiento y posibles integraciones futuras.
- **Versionado de assets:** Implementar cache busting con hash en los nombres de archivos CSS/JS para forzar la recarga tras actualizaciones.

Sección 14 Anexo

Flujo de Datos Detallado por Módulo

Flujo: Publicación de Noticia

El siguiente flujo describe el proceso completo desde que el administrador sube una noticia hasta que aparece en el sitio público:

1. El administrador accede a `admin/noticias.php`. `auth_guard.php` verifica la sesión activa y los permisos de sección.
2. Se genera un token CSRF y se renderiza el formulario de nueva noticia con campos: título, descripción, fecha y archivo de imagen.
3. El administrador completa el formulario y hace clic en "Guardar".
4. El navegador envía una petición POST multipart a `admin/noticias.php` con `action=add`.
5. `auth_guard.php` intercepta el POST, valida el token CSRF y registra la acción en `admin_historial`.
6. El módulo valida los campos requeridos (título, fecha).
7. Si se adjuntó imagen, se llama a `handle_upload($_FILES['imagen'], 'image')`: validación MIME, tamaño, extensión, sanitización del nombre, movimiento a `uploads/images/` y compresión GD.
8. Se ejecuta la sentencia PDO preparada: `INSERT INTO noticias_imagenes (titulo, descripcion, fecha_noticia, imagen_path) VALUES (?, ?, ?, ?)`.
9. Se establece un mensaje flash de éxito en `$_SESSION['flash_message']` y se redirige con `header('Location: noticias')`.
10. El sitio público `comunicacion-social/noticias.php` consulta `SELECT * FROM noticias_imagenes ORDER BY fecha_noticia DESC` y renderiza las noticias con Lightbox2.

Flujo: Subida de Documento de Transparencia (PDF)

1. El administrador accede al módulo de transparencia correspondiente (ej: `admin/seac.php`).
2. Selecciona el bloque anual y el concepto al que desea adjuntar el PDF.
3. Hace clic en "Subir PDF" y selecciona el archivo desde su equipo.
4. El formulario envía POST con `action=upload_pdf`, `concepto_id` y el archivo PDF.
5. `handle_upload($_FILES['pdf'], 'pdf')` valida: error PHP, tamaño máximo 50 MB, extensión `.pdf`, MIME real `application/pdf`.
6. El archivo se mueve a `uploads/pdfs/` con nombre sanitizado.
7. Se inserta el registro en la tabla correspondiente (ej: `seac_pdfs`) con la ruta relativa del PDF.
8. En el panel admin, el PDF aparece en la lista con un botón "Ver" que abre el modal visor (iframe con PDF.js).
9. En el sitio público, el PDF se enlaza con un botón de descarga/visualización.

Flujo: Reordenamiento con SortableJS

1. El administrador arrastra un elemento de la lista en el panel admin.
2. SortableJS actualiza el orden visual en el DOM y dispara el evento `onEnd`.
3. El handler JavaScript serializa el nuevo orden como array JSON: `[{"id":3,"orden":1},{"id":1,"orden":2}]`.

4. Se envía una petición AJAX POST con `action=reorder`, `csrf_token` y el array JSON.
5. El servidor valida el CSRF, decodifica el JSON y ejecuta un UPDATE por cada elemento: `UPDATE tabla SET orden = ? WHERE id = ?`.
6. Se retorna `{"success":true}` y el frontend muestra una notificación de éxito.
7. El sitio público consulta los registros con `ORDER BY orden ASC` y los presenta en el nuevo orden.

Flujo: Creación de Sección de Transparencia Dinámica

1. El administrador accede a `admin/transparencia_dinamica.php`.
2. Completa el formulario: nombre de la sección, slug URL, plantilla a reutilizar (ej: `seac`), ícono Bootstrap Icons.
3. El sistema valida que el slug sea único en `trans_secciones`.
4. Se inserta el registro en `trans_secciones` con la plantilla seleccionada.
5. La nueva sección aparece automáticamente en el menú de transparencia del sitio público.
6. Al acceder a la sección, el sistema carga la plantilla correspondiente y consulta los datos de las tablas `trans_bloques`, `trans_conceptos` y `trans_pdfs` filtrados por `seccion_id`.
7. El administrador puede gestionar el contenido de la nueva sección desde `admin/transparencia_seccion.php?id=[seccion_id]`.

Flujo: Gestión de Álbum Fotográfico

1. El administrador crea un nuevo álbum en `admin/galeria.php` con nombre, fecha y portada.
2. Se inserta en `galeria_albumes` y se sube la imagen de portada a `uploads/images/`.
3. El administrador accede al álbum y sube imágenes individuales (subida múltiple soportada).
4. Cada imagen se procesa con `handle_upload()` y se inserta en `galeria_imagenes` con referencia al `album_id`.
5. El sitio público `comunicacion-social/galeria.php` consulta los álbumes activos y sus imágenes.
6. Las imágenes se presentan en una cuadrícula con Lightbox2 para visualización en modal con navegación entre fotos del álbum.

Consideraciones de Integridad de Datos

El sistema implementa las siguientes medidas para mantener la integridad de los datos:

- **Eliminación en cascada:** Las tablas con relaciones de clave foránea usan `ON DELETE CASCADE` para eliminar registros dependientes automáticamente (ej: eliminar un álbum elimina todas sus imágenes en `galeria_imagenes`).
- **Eliminación de archivos físicos:** Al eliminar un registro con archivo asociado, el sistema elimina también el archivo del servidor con `unlink()`.
- **Unicidad de slugs:** Los slugs de trámites y secciones de transparencia tienen restricción `UNIQUE KEY` para evitar duplicados.
- **Transacciones:** Las operaciones que involucran múltiples tablas (ej: crear álbum + subir portada) se realizan en secuencia con manejo de errores para revertir cambios parciales.
- **Validación de existencia:** Antes de eliminar un archivo físico, se verifica que el archivo exista con `file_exists()` para evitar errores de PHP.

Sección 15

Registro de Cambios (Changelog)

Versión 1.0.0 □ Lanzamiento Inicial

Fecha de desarrollo: 2025□2026 | **Autor:** Sergio Huitron Gomez

Módulos Implementados

Módulo	Descripción	Estado
Autenticación	Login con bcrypt, CSRF, rate limiting, auto-logout por inactividad (5 min), session regeneration	Completo
Sistema de Permisos	Roles admin/usuario, permisos granulares por sección, tabla admin_permisos	Completo
Historial de Auditoría	Registro automático de todas las acciones POST, detección de dispositivo y navegador, reportes	Completo
Slider Principal	Carrusel Swiper.js, subida de imágenes, reordenamiento drag&drop, toggle activo	Completo
Slider DIF Comunica	Carrusel OwlCarousel2, organización por mes/año	Completo
Programas Sociales	Estructura jerárquica 3 niveles, editor TinyMCE, reordenamiento	Completo
Trámites y Servicios	6 trámites con slugs fijos, editor TinyMCE, galería de imágenes	Completo
Noticias	Publicación de noticias con imagen, título, descripción y fecha	Completo
Galería Fotográfica	Álbumes con portada, subida múltiple, Lightbox2, reordenamiento	Completo
Presidencia	Información de la presidenta con editor TinyMCE y fotografía	Completo
Direcciones	Directorio de directores y jefes de área con fotografías	Completo
Organigrama	Subida y actualización de imagen del organigrama institucional	Completo
Voluntariado	Configuración de página de voluntariado con galería de imágenes	Completo
Unidad de Autismo	Configuración de página de la Unidad de Autismo con TinyMCE	Completo
Footer	Configuración de pie de página: datos institucionales y enlaces por columnas	Completo
Banner Institucional	Imagen y texto del banner de la página de inicio	Completo
SEAC	Módulo de transparencia SEAC con bloques anuales, conceptos y PDFs trimestrales	Completo

Cuenta Pública	Módulo de cuenta pública con estructura jerárquica bloque?título?concepto	Completo
Presupuesto Anual	Módulo de presupuesto anual con bloques, conceptos y PDFs	Completo
PAE	Programa Anual de Evaluación con títulos y PDFs por año	Completo
Matrices de Indicadores	PDFs de matrices de indicadores organizados por año	Completo
CONAC	Módulo CONAC con estructura similar a SEAC	Completo
Financiero	Información financiera con bloques anuales y conceptos	Completo
Avisos de Privacidad	Gestión de avisos de privacidad con editor TinyMCE	Completo
Transparencia Dinámica	Creación de nuevas secciones de transparencia sin modificar código, con 7 plantillas reutilizables	Completo
Gestión de Usuarios	CRUD de usuarios del panel, roles, permisos, activación/desactivación, restablecimiento de contraseña	Completo
Upload Handler	Manejador centralizado de subida con validación MIME, compresión GD, logs de errores	Completo
Visor PDF Admin	Modal con iframe para visualizar PDFs directamente en el panel sin salir de la página	Completo

Características Técnicas Implementadas

- Conexión PDO singleton con charset utf8mb4 y sentencias preparadas nativas
- Protección CSRF con tokens criptográficos de 256 bits y soporte multi-pestaña
- Rate limiting de login: máximo 5 intentos por IP en ventana de 15 minutos
- Auto-logout por inactividad: 5 minutos (PHP + JavaScript)
- Compresión automática de imágenes: máx. 1920px, JPEG/WEBP 85%, PNG nivel 6
- Validación MIME real con PHP finfo (no confía en extensión del cliente)
- Registro de auditoría automático con detección de dispositivo y navegador
- Sistema de permisos granular por archivo PHP de sección
- Sidebar colapsable con grupos y estado activo persistente
- Reordenamiento drag & drop con SortableJS en todos los módulos aplicables
- Editor TinyMCE 6 integrado en todos los módulos con contenido HTML enriquecido
- Soporte de múltiples pestañas del navegador con pool de tokens CSRF
- Mensajes flash de sesión para retroalimentación tras operaciones POST
- Output buffering para prevenir errores "headers already sent"
- Fallback de jQuery local cuando el CDN no está disponible

Sección 16

Glosario Técnico

Término	Definición
Apache	Servidor web HTTP de código abierto. En este sistema, procesa las peticiones HTTP, aplica las reglas de `.htaccess` y ejecuta los scripts PHP mediante mod_php o PHP-FPM.
bcrypt	Algoritmo de hashing de contraseñas basado en Blowfish. Incorpora un "salt" aleatorio y un factor de costo configurable que hace que el cómputo sea intencionalmente lento, dificultando los ataques de fuerza bruta. PHP lo implementa con `password_hash()` y `password_verify()`.
Bootstrap 5	Framework CSS de código abierto para desarrollo web responsive. Proporciona un sistema de grid de 12 columnas, componentes UI prediseñados (modales, alertas, botones, formularios) y utilidades CSS.
CDN (Content Delivery Network)	Red de servidores distribuidos geográficamente que sirven contenido estático (CSS, JS, fuentes) desde el servidor más cercano al usuario, reduciendo la latencia de carga.
CMS (Content Management System)	Sistema de Gestión de Contenido. Software que permite crear, editar, organizar y publicar contenido digital sin necesidad de conocimientos de programación.
CONAC	Consejo Nacional de Armonización Contable. Órgano de gobierno que emite las normas y lineamientos contables para los entes públicos en México.
cPanel	Panel de control de hosting web que proporciona una interfaz gráfica para gestionar sitios web, bases de datos, correos electrónicos, dominios y configuraciones del servidor.
CSRF (Cross-Site Request Forgery)	Ataque que engaña al navegador del usuario para que envíe peticiones no autorizadas a un sitio web en el que está autenticado. Se previene con tokens únicos por formulario.
DSN (Data Source Name)	Cadena de conexión que especifica el tipo de base de datos, host, nombre de base de datos y charset para PDO. Formato: `mysql:host=localhost;dbname=nombre;charset=utf8mb4`.
finfo	Extensión PHP que detecta el tipo MIME real de un archivo analizando su contenido binario (magic bytes), independientemente de la extensión del archivo o el tipo MIME declarado por el cliente.
GD Library	Biblioteca de PHP para creación y manipulación de imágenes. Permite redimensionar, comprimir y convertir imágenes en formatos JPEG, PNG y WEBP.
hash_equals()	Función PHP que compara dos cadenas en tiempo constante, independientemente de su longitud. Previene ataques de timing que podrían revelar información sobre el valor secreto comparado.
htaccess	Archivo de configuración de Apache a nivel de directorio. Permite configurar reglas de reescritura de URLs, protección de directorios, cabeceras HTTP y otras directivas sin modificar la configuración global del servidor.

InnoDB	Motor de almacenamiento de MySQL que soporta transacciones ACID, claves foráneas con integridad referencial y bloqueo a nivel de fila. Es el motor por defecto en MySQL 8.
jQuery	Biblioteca JavaScript que simplifica la manipulación del DOM, el manejo de eventos, las animaciones y las peticiones AJAX. Ampliamente utilizada para compatibilidad con plugins como OwlCarousel2 y Lightbox2.
Lightbox2	Plugin jQuery que muestra imágenes en un modal superpuesto sobre la página, con navegación entre imágenes de una galería. Utilizado en la sección de galería fotográfica del sitio público.
MIME (Multipurpose Internet Mail Extensions)	Estándar que define el tipo de contenido de un archivo. Ejemplos: `image/jpeg`, `application/pdf`, `text/html`. En el sistema, se valida el MIME real del archivo subido con finfo.
mod_rewrite	Módulo de Apache que permite reescribir URLs dinámicamente mediante expresiones regulares. Utilizado para crear URLs amigables y redirigir peticiones.
MVC (Model-View-Controller)	Patrón de arquitectura de software que separa la aplicación en tres componentes: Modelo (datos y lógica de negocio), Vista (presentación) y Controlador (manejo de peticiones). El sistema implementa una variante procedimental simplificada de este patrón.
OwlCarousel2	Plugin jQuery para crear carruseles/sliders responsive con soporte táctil. Utilizado en la sección "DIF Comunica" del sitio público.
PAE (Programa Anual de Evaluación)	Documento de planeación que establece los programas y acciones a evaluar durante el ejercicio fiscal, conforme a la normativa de evaluación del desempeño gubernamental.
PDO (PHP Data Objects)	Extensión PHP que proporciona una interfaz uniforme para acceder a diferentes motores de base de datos. Soporta sentencias preparadas que previenen inyección SQL.
PDF.js	Biblioteca JavaScript de Mozilla para renderizar documentos PDF directamente en el navegador sin plugins externos. Utilizada en el panel de administración para previsualizar PDFs.
Rate Limiting	Técnica de seguridad que limita el número de peticiones que un cliente puede realizar en un período de tiempo determinado. En este sistema, limita los intentos de login a 5 por IP en 15 minutos.
Salt	Valor aleatorio único que se agrega a la contraseña antes de aplicar el hash. Previene ataques de diccionario y rainbow tables. bcrypt genera e incorpora el salt automáticamente en el hash resultante.
SEAC	Sistema de Evaluación y Acreditación de la Calidad. Marco de referencia para evaluar y mejorar la calidad de los servicios públicos municipales en el Estado de México.
Session Fixation	Ataque en el que un atacante establece el ID de sesión de un usuario antes de que se autentique, para luego usar ese ID y acceder a la sesión autenticada. Se previene con `session_regenerate_id(true)` tras el login.
Singleton	Patrón de diseño que garantiza que una clase tenga una única instancia durante la ejecución del programa. En este sistema, la conexión PDO es un singleton implementado con una variable estática en `get_db()`.
Slug	Versión URL-friendly de un texto, generalmente en minúsculas, sin espacios ni caracteres especiales. Ejemplo: "Cuenta Pública 2024" ? `cuenta-publica-2024`. Utilizado para identificar trámites y secciones de transparencia en las URLs.

SortableJS	Biblioteca JavaScript para implementar funcionalidad de arrastrar y soltar (drag & drop) en listas y grids. Utilizada en el panel de administración para reordenar elementos de sliders, programas, galería y otros módulos.
SQL Injection	Ataque que inserta código SQL malicioso en los parámetros de entrada de una aplicación para manipular las consultas a la base de datos. Se previene con sentencias preparadas PDO.
Swiper.js	Biblioteca JavaScript moderna para crear carruseles/sliders con soporte táctil, transiciones CSS3 y API flexible. Utilizada en el carrusel principal de la página de inicio.
TinyMCE	Editor de texto enriquecido (WYSIWYG) basado en JavaScript. Permite a los usuarios crear y editar contenido HTML sin conocer el lenguaje de marcado. Versión 6 utilizada en este sistema.
Token CSRF	Valor aleatorio único generado por el servidor e incluido en cada formulario HTML. Al procesar el formulario, el servidor verifica que el token enviado coincida con el almacenado en la sesión, confirmando que la petición proviene del sitio legítimo.
utf8mb4	Codificación de caracteres MySQL que soporta el conjunto completo de Unicode, incluyendo emojis y caracteres de idiomas asiáticos. Supera las limitaciones de `utf8` de MySQL que solo soporta caracteres de 3 bytes.
WEBP	Formato de imagen moderno desarrollado por Google que ofrece mejor compresión que JPEG y PNG con calidad visual equivalente. Soportado por todos los navegadores modernos.
WOW.js	Biblioteca JavaScript que activa animaciones CSS (de Animate.css) cuando los elementos entran en el viewport al hacer scroll. Utilizada para efectos de entrada en el sitio público.
XAMPP	Paquete de software de código abierto que incluye Apache, MySQL, PHP y Perl. Utilizado como entorno de desarrollo local en Windows para este proyecto.
XSS (Cross-Site Scripting)	Ataque que inyecta scripts maliciosos en páginas web vistas por otros usuarios. Se previene escapando los datos dinámicos con `htmlspecialchars()` antes de renderizarlos en HTML.

© 2025□2026 Sergio Huitron Gomez. Todos los derechos reservados.